Frontend API Reference (Auth + Core)

This document is written for frontend developers to integrate with the current backend endpoints.

- Base URL (local): `http://127.0.0.1:8000`
- Swagger UI: `/`
- OpenAPI schema: `/api/schema/`
- All endpoints below include a trailing slash.

Authentication

JWT header

For protected endpoints, send:

- `Authorization: Bearer <access_token>`

Tokens

- `access`: short-lived JWT access token
- `refresh`: long-lived refresh token

Token claims also include `user_id`, `email`, `role`, `full_name`.

Auth endpoints (`/api/auth/`)

Register

- **POST** `/api/auth/register/`
- **Auth**: No
- **Creates**: User with role `customer` by default
- **Content-Type**: `application/json` (or `multipart/form-data` if uploading `profile_image`)

Request body fields

Required:

- `email` (string, unique)
- `full_name` (string)
- `password` (string)
- `password_confirm` (string; must match `password`)

Optional:

- `phone` (string; digits with optional leading `+`; can be null)
- `profile_image` (file upload)

Example (JSON)

```
{
  "email": "user@example.com",
  "full_name": "John Doe",
  "phone": "201234567890",
  "password": "StrongPassword123!",
  "password_confirm": "StrongPassword123!"
}
```

Success response

- **201 Created**

```
{
  "message": "User registered successfully",
  "refresh": "<refresh_token>",
  "access": "<access_token>",
  "access_expires_at": "2025-12-29T15:00:00+00:00",
  "refresh_expires_at": "2026-01-28T15:00:00+00:00",
  "access_expires_in": 86400,
  "refresh_expires_in": 2592000,
  "user": {
    "id": 1,
    "email": "user@example.com",
    "full_name": "John Doe",
    "phone": "201234567890",
    "role": "customer",
    "profile_image": null,
    "is_active": true,
    "created_at": "2025-12-25T12:34:56Z",
    "updated_at": "2025-12-25T12:34:56Z"
  }
}
```

Common error responses

- **400 Bad Request** (validation)

```
{
  "email": ["A user with this email already exists."]
}
```

```
{
  "password": ["Password fields didn't match."]
}
```

```
{
  "password": ["This password is too short. It must contain at least 8
characters."]
}
```

Login

- **POST** `/api/auth/login/`
- **Auth**: No
- **Content-Type**: `application/json`

Request body fields

Required:

- `email` (string)
- `password` (string)

Example

```
{
  "email": "user@example.com",
  "password": "StrongPassword123!"
}
```

Success response

- **200 OK**

```
{
  "refresh": "<refresh_token>",
  "access": "<access_token>",
  "access_expires_at": "2025-12-29T15:00:00+00:00",
  "refresh_expires_at": "2026-01-28T15:00:00+00:00",
  "access_expires_in": 86400,
  "refresh_expires_in": 2592000,
  "user": {
    "id": 1,
    "email": "user@example.com",
    "full_name": "John Doe",
    "role": "customer",
    "phone": "+201234567890",
    "profile_image": null
  }
}
```

```
**Token expiry fields**

- `access_expires_at`, `refresh_expires_at`: ISO timestamps
- `access_expires_in`, `refresh_expires_in`: seconds remaining (dynamic)
```

Common error responses

- **401 Unauthorized**

```
{
  "detail": "No active account found with the given credentials"
}
```

Refresh token

- **POST** `/api/auth/refresh/`
- **Auth**: No
- **Content-Type**: `application/json`

Request body fields

Required:

- `refresh` (string)

Example

```
{
  "refresh": "<refresh_token>"
}
```

Success response

- **200 OK**

With rotation enabled, the backend may return both a new access token and a new refresh token:

```
{
  "access": "<new_access_token>",
  "refresh": "<new_refresh_token>"
}
```

If rotation is disabled in the future, response may be:

```
{
  "access": "<new_access_token>"
}
```

Common error responses

- **401 Unauthorized** (expired/invalid refresh token)

```
{
  "detail": "Token is invalid or expired",
  "code": "token_not_valid"
}
```

Logout (blacklist refresh token)

- **POST** `/api/auth/logout/`
- **Auth**: Yes (access token required)
- **Content-Type**: `application/json`

Request body fields

Required:

- `refresh` (string)

Example

```
{
  "refresh": "<refresh_token>"
}
```

Success response

- **205 Reset Content**

```
{
  "message": "Successfully logged out"
}
```

Common error responses

- **400 Bad Request** (missing/invalid refresh)

```
{
  "error": "Refresh token is required"
}
```

- **401 Unauthorized** (missing/invalid access token)

Me (current user profile)

- **GET** `/api/auth/me/` (retrieve)
- **PATCH** `/api/auth/me/` (partial update)
- **PUT** `/api/auth/me/` (full update)
- **Auth**: Yes

Response fields

```
{
  "id": 1,
  "email": "user@example.com",
  "full_name": "John Doe",
  "phone": "+201234567890",
  "role": "customer",
  "profile_image": null,
  "is_active": true,
  "created_at": "2025-12-25T12:34:56Z",
  "updated_at": "2025-12-25T12:35:10Z"
}
```

Updatable fields

- `email` (string)
- `full_name` (string)
- `phone` (string or null)
- `profile_image` (file upload; use `multipart/form-data`)
- `is_active` (boolean)

Not updatable:

- `role` (read-only)
- `created_at`, `updated_at` (read-only)

PATCH example (JSON)

```
{
  "full_name": "John Doe Updated",
  "phone": "+201000000000"
}
```

Common error responses

- **401 Unauthorized** (missing/invalid token)

Authorization & roles (summary)

Roles (string values):

- `customer`
- `developer`
- `content_creator`
- `staff`
- `manager`
- `superadmin`

Core permission rules implemented in `apps/core/permissions.py`.

Core API endpoints (`/api/`)

Common responses

- List: **200 OK** → JSON array of objects
- Retrieve: **200 OK** → JSON object
- Create: **201 Created** → created JSON object
- Update (PUT/PATCH): **200 OK** → updated JSON object
- Delete: **204 No Content**

Common errors

- **400 Bad Request**: serializer validation errors
- **401 Unauthorized**: missing/invalid JWT on protected routes
- **403 Forbidden**: authenticated but insufficient role
- **404 Not Found**: invalid `{id}`

Uploading `image` fields

Several core resources include an `image` field.

- When sending an image file, use `multipart/form-data`.
- When not uploading a file (e.g., only changing text fields), `application/json` is fine.

Allowed image formats (server validation)

- WebP only: Countries, Cities, Articles, and any other like units , projects ,...
- Multiple formats allowed: Sliders, Ads, Developer `logo` (jpg/jpeg/png/webp)

Countries

- Resource: `/api/countries/`

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superadmin: `POST`, `PUT`, `PATCH`
- Manager/Superadmin: `DELETE`

Fields

Required on create:

- `name_en` (string)
- `name_ar` (string)
- `image` (file)

Optional:

- `appear_on_home_page` (boolean; defaults to `false`)

Read-only:

- `id`
- `created_at`

Create example (multipart/form-data)

Fields:

- `name_en`: `Egypt`
- `name_ar`: `مصر`
- `appear_on_home_page`: `true`
- `image`: (file)

Response example

```
{
  "id": 1,
  "name_en": "Egypt",
  "name_ar": "مصر",
  "image": "/media/countries/egypt.png",
  "appear_on_home_page": true,
  "created_at": "2025-12-25T12:34:56Z"
}
```

Cities

- Resource: `/api/cities/`

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superadmin: `POST`, `PUT`, `PATCH`
- Manager/Superadmin: `DELETE`

Fields

Required on create:

- `country` (number; Country ID)
- `name_en` (string)
- `name_ar` (string)
- `image` (file)

Optional:

- `appear_on_home_page` (boolean; defaults to `false`)

Read-only:

- `id`
- `country_name` (string; derived from country `name_en`)
- `created_at`
- `updated_at`

Create example (multipart/form-data)

Fields:

- `country`: `1`
- `name_en`: `Cairo`
- `name_ar`: `القاهرة`
- `appear_on_home_page`: `true`
- `image`: (file)

Response example

```
{
  "id": 1,
  "country": 1,
  "country_name": "Egypt",
  "name_en": "Cairo",
  "name_ar": "القاهرة",
  "image": "/media/cities/cairo.png",
  "appear_on_home_page": true,
  "created_at": "2025-12-25T12:34:56Z",
  "updated_at": "2025-12-25T12:34:56Z"
}
```

Sliders

- Resource: `/api/sliders/`

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superadmin: `POST`, `PUT`, `PATCH`
- Manager/Superadmin: `DELETE`

Fields

Required on create:

- `image` (file)

Optional:

- `appear_on_home_page` (boolean; defaults to `true`)
- `index` (number; controls ordering; lower comes first)

Read-only:

- `id`
- `created_at`

Response example

```
{
  "id": 1,
  "image": "/media/sliders/slide1.jpg",
  "appear_on_home_page": true,
  "index": 0,
  "created_at": "2025-12-25T12:34:56Z"
}

**Ordering**

- Sliders are returned ordered by `index` ascending, then `id`.
```

Ads

- Resource: `/api/ads/`

Permissions

- Public: `GET` (list/retrieve)

- Staff/Manager/Superadmin: `POST`, `PUT`, `PATCH`
- Manager/Superadmin: `DELETE`

Fields

Required on create:

- `image` (file)
- `appear_place` (string; one of: `home`, `projects`, `units`, `other`)

Read-only:

- `id`
- `created_at`

Create example (multipart/form-data)

Fields:

- `appear_place`: `home`
- `image`: (file)

Response example

```
{
  "id": 1,
  "image": "/media/ads/ad1.jpg",
  "appear_place": "home",
  "created_at": "2025-12-25T12:34:56Z"
}
```

Features

- Resource: `/api/features/`

Permissions

- Public: `GET` (list/retrieve)
- Staff/Manager/Superadmin: `POST`, `PUT`, `PATCH`
- Manager/Superadmin: `DELETE`

Fields

Required on create:

- `name_en` (string)
- `name_ar` (string)

Read-only:

- `id`

Response example

```
{
  "id": 1,
  "name_en": "Swimming Pool",
  "name_ar": "حمام سباحة"
}
```

Articles

- Resource: `/api/articles/`

Permissions

- Public: `GET` (list/retrieve)
- Content Creator / Staff / Manager / Superadmin: `POST`, `PUT`, `PATCH`
- Content Creator / Manager / Superadmin: `DELETE`

Fields

Required on create:

- `title_en` (string)
- `title_ar` (string)
- `content_en_md` (string; markdown)
- `content_ar_md` (string; markdown)
- `image` (file)

Optional:

- `meta` (object; can be null)

Read-only:

- `id`
- `created_at`
- `updated_at`

Create example (multipart/form-data)

Fields:

- `title_en`: `Market Update`
- `title_ar`: `تحديث السوق`
- `content_en_md`: `# Heading\n\nMarkdown...`
- `content_ar_md`: `# عنوان\n\nMarkdown...`
- `meta`: `{ "tags": ["news"], "reading_time": 5 }`

- `image`: (file)

Response example

```
{
  "id": 1,
  "title_en": "Market Update",
  "title_ar": "تحديث السوق",
  "content_en_md": "# Heading\n\nMarkdown...",
  "content_ar_md": "# عنوان\n\nMarkdown...",
  "meta": {"tags": ["news"], "reading_time": 5},
  "image": "/media/articles/article1.jpg",
  "created_at": "2025-12-25T12:34:56Z",
  "updated_at": "2025-12-25T12:34:56Z"
}
```

Permission quick matrix (core)

- **Public (no token)**: list/retrieve for all core resources
- **Staff/Manager/Superadmin**: create/update for Countries, Cities, Sliders, Ads, Features
- **Manager/Superadmin**: delete for Countries, Cities, Sliders, Ads, Features
- **Articles**:
  - create/update: Content Creator OR Staff OR Manager OR Superadmin
  - delete: Content Creator OR Manager OR Superadmin